

LAB 01 — CROSS-SITE SCRIPTING

MSSV: 21127645 — Họ tên: Lê Minh

Mục tiêu và an toàn

Trace dữ liệu thật qua Browser → HTTP → Flask → SQLite/Jinja → Response → DOM. Chỉ chạy tại 127.0.0.1.

Reflected XSS

Source: request.args["q"] → Transform → Sink: Markup(q) trong HTML → Result. Bản vá: Jinja autoescape.

STT	Layer	Hành động	Kỹ thuật	Output
1	Browser UI	Nhập payload	HTML form	Dữ liệu tainted
2	HTTP Request	Tạo GET	Percent encoding	Query string
3	Flask Router	Đọc q	URL decode	Python string
4	Server Validation	Giới hạn 200	Length check	q hợp lệ
5	Template Engine	Render q	Markup hoặc autoescape	HTML unsafe/text
6	HTTP Response	Trả HTML	HTTP	Response body
7	Browser Parser	Parse response	HTML parser	Element hoặc text node
8	Final Result	Kết luận	Event/text	Executed hoặc blocked

Stored XSS

Source: request.form["body"] → comments.body → Transform → Sink: Markup(row[body]) → Result. Bản vá: Bleach allowlist + Jinja.

STT	Layer	Hành động	Kỹ thuật	Output
1	Browser UI	Nhập comment	HTML form	Form data
2	HTTP Request	POST	urlencoded body	request.form
3	Flask Router	Đọc form	Flask	Python string
4	Validation	Kiểm tra rỗng/độ dài	Length check	Hợp lệ
5	SQLite	INSERT	Parameterized SQL	Stored row
6	SQLite	SELECT	Parameterized SQL	Rows
7	Template Engine	Render body	Markup/Bleach	Unsafe/sanitized HTML
8	Browser Parser	Parse comment	Parser	Event/text
9	Final Result	Reload	Repeat render	Executed hoặc blocked

DOM-based XSS

Source: location.hash → Transform → Sink: innerHTML → Result. Bản vá: textContent.

STT	Layer	Hành động	Kỹ thuật	Output
1	Browser UI	Đổi fragment	hashchange	Client state
2	HTTP Request	Gửi path	HTTP semantics	Không có fragment
3	Browser JavaScript	Đọc hash	slice/decodeURIComponent	Decoded value
4	DOM	Gán sink	innerHTML/textContent	Element/text node
5	DOM Inspector	Đọc outerHTML	DOM API	Tag/event count
6	Final Result	Kết luận	Browser event	Executed hoặc blocked

CSP, cookie và kiểm thử

CSP là lớp bổ sung; HttpOnly không vá XSS; production HTTPS phải bật Secure cookie.

..... [100%] 13 passed in 1.44s

01_home_overview.png

ẢNH CẦN BỔ SUNG: 01_home_overview.png
URL: /
Thao tác: Mở trang chủ
Phải xuất hiện: Tên Lab01, ba loại XSS và liên kết vulnerable/secure

Caption: Tên Lab01, ba loại XSS và liên kết vulnerable/secure

02_reflected_input_step.png

ẢNH CẦN BỔ SUNG: 02_reflected_input_step.png
URL: /vulnerable/search
Thao tác: Nhập payload nhưng chưa gửi
Phải xuất hiện: Ô input và payload

Caption: Ô input và payload

03_reflected_request_step.png

ẢNH CẦN BỔ SUNG: 03_reflected_request_step.png
URL: /vulnerable/search
Thao tác: Gửi form, mở tab Request
Phải xuất hiện: GET, route, query string, URL encoded

Caption: GET, route, query string, URL encoded

04_reflected_server_step.png

ẢNH CẦN BỔ SUNG: 04_reflected_server_step.png
URL: /vulnerable/search
Thao tác: Chọn bước Flask Router/Validation
Phải xuất hiện: request.args["q"] và dữ liệu decoded

Caption: request.args["q"] và dữ liệu decoded

05_reflected_template_step.png

ẢNH CẦN BỔ SUNG: 05_reflected_template_step.png
URL: /vulnerable/search
Thao tác: Chọn Template Engine
Phải xuất hiện: Markup(q), dữ liệu chưa escape

Caption: Markup(q), dữ liệu chưa escape

06_reflected_browser_parse_step.png

ẢNH CẦN BỔ SUNG: 06_reflected_browser_parse_step.png
URL: /vulnerable/search
Thao tác: Chọn Browser HTML Parser
Phải xuất hiện: img element và onerror

Caption: img element và onerror

07_reflected_payload_executed.png

ẢNH CẦN BỔ SUNG: 07_reflected_payload_executed.png
URL: /vulnerable/search
Thao tác: Chạy payload rồi xem verdict
Phải xuất hiện: Alert hoặc verdict payload_executed

Caption: Alert hoặc verdict payload_executed

08_reflected_secure_encoding.png

ẢNH CẦN BỔ SUNG: 08_reflected_secure_encoding.png
URL: /secure/search
Thao tác: Gửi cùng payload
Phải xuất hiện: HTML escaped và text node

Caption: HTML escaped và text node

09_reflected_comparison.png

ẢNH CẦN BỔ SUNG: 09_reflected_comparison.png
URL: /secure/search
Thao tác: Mở tab So sánh mã
Phải xuất hiện: Markup(q) cạnh Jinja autoescape

Caption: Markup(q) cạnh Jinja autoescape

10_stored_post_request.png

ẢNH CẦN BỔ SUNG: 10_stored_post_request.png
URL: /vulnerable/post/1/comments
Thao tác: POST bình luận payload, mở Request
Phải xuất hiện: Form body đã che cookie

Caption: Form body đã che cookie

11_stored_database_insert.png

ẢNH CẦN BỔ SUNG: 11_stored_database_insert.png
URL: /vulnerable/post/1/comments
Thao tác: Chọn SQLite INSERT
Phải xuất hiện: Parameterized query và dữ liệu lưu

Caption: Parameterized query và dữ liệu lưu

12_stored_database_record.png

ẢNH CẦN BỔ SUNG: 12_stored_database_record.png
URL: /vulnerable/post/1/comments
Thao tác: Mở Database Inspector
Phải xuất hiện: Bản ghi payload thật trong SQLite

Caption: Bản ghi payload thật trong SQLite

13_stored_template_render.png

ẢNH CẦN BỔ SUNG: 13_stored_template_render.png
URL: /vulnerable/post/1/comments
Thao tác: Reload, chọn Template Engine
Phải xuất hiện: SELECT rồi render Markup

Caption: SELECT rồi render Markup

14_stored_payload_reload.png

ẢNH CẦN BỔ SUNG: 14_stored_payload_reload.png
URL: /vulnerable/post/1/comments
Thao tác: Reload và xem verdict
Phải xuất hiện: Alert hoặc payload_executed

Caption: Alert hoặc payload_executed

15_stored_secure_escape.png

ẢNH CẦN BỔ SUNG: 15_stored_secure_escape.png
URL: /secure/post/1/comments
Thao tác: Mở bản secure
Phải xuất hiện: Dữ liệu DB không thực thi

Caption: Dữ liệu DB không thực thi

16_stored_secure_sanitize.png

ẢNH CẦN BỔ SUNG: 16_stored_secure_sanitize.png
URL: /secure/post/1/comments
Thao tác: POST img + strong, mở Biến đổi
Phải xuất hiện: Trước/sau Bleach sanitization

Caption: Trước/sau Bleach sanitization

17_stored_comparison.png

ẢNH CẦN BỔ SUNG: 17_stored_comparison.png
URL: /secure/post/1/comments
Thao tác: Mở So sánh mã
Phải xuất hiện: Markup cạnh bleach.clean

Caption: Markup cạnh bleach.clean

18_dom_hash_source.png

ẢNH CẦN BỔ SUNG: 18_dom_hash_source.png
URL: /vulnerable/dom-search
Thao tác: Đặt fragment payload
Phải xuất hiện: location.href và location.hash

Caption: location.href và location.hash

19_dom_javascript_read.png

ẢNH CẦN BỔ SUNG: 19_dom_javascript_read.png
URL: /vulnerable/dom-search
Thao tác: Chọn Browser JavaScript
Phải xuất hiện: Giá trị trước/sau decodeURIComponent

Caption: Giá trị trước/sau decodeURIComponent

20_dom_innerhtml_sink.png

ẢNH CẦN BỔ SUNG: 20_dom_innerhtml_sink.png
URL: /vulnerable/dom-search
Thao tác: Chọn bước DOM
Phải xuất hiện: innerHTML và dữ liệu sink

Caption: innerHTML và dữ liệu sink

21_dom_element_created.png

ẢNH CẦN BỔ SUNG: 21_dom_element_created.png
URL: /vulnerable/dom-search
Thao tác: Xem DOM Inspector
Phải xuất hiện: img element và onerror trong DOM thật

Caption: img element và onerror trong DOM thật

22_dom_payload_executed.png

ẢNH CẦN BỔ SUNG: 22_dom_payload_executed.png
URL: /vulnerable/dom-search
Thao tác: Chạy fragment
Phải xuất hiện: Alert hoặc verdict payload_executed

Caption: Alert hoặc verdict payload_executed

23_dom_textcontent_fix.png

ẢNH CẦN BỔ SUNG: 23_dom_textcontent_fix.png
URL: /secure/dom-search
Thao tác: Đặt cùng fragment
Phải xuất hiện: textContent và text node

Caption: textContent và text node

24_dom_comparison.png

ẢNH CẦN BỔ SUNG: 24_dom_comparison.png
URL: /secure/dom-search
Thao tác: Mở So sánh mã
Phải xuất hiện: innerHTML cạnh textContent

Caption: innerHTML cạnh textContent

25_csp_headers.png

ẢNH CẦN BỔ SUNG: 25_csp_headers.png
URL: /security-headers
Thao tác: Mở bảng và trace CSP
Phải xuất hiện: CSP cùng directive chính

Caption: CSP cùng directive chính

26_cookie_security.png

ẢNH CẦN BỔ SUNG: 26_cookie_security.png
URL: /profile
Thao tác: Mở bảng cookie
Phải xuất hiện: HttpOnly, SameSite, Secure local/production

Caption: HttpOnly, SameSite, Secure local/production

27_presentation_mode.png

ẢNH CẦN BỔ SUNG: 27_presentation_mode.png
URL: /secure/search?q=demo
Thao tác: Bật Presentation Mode
Phải xuất hiện: Bước hiện tại và thanh tiến trình

Caption: Bước hiện tại và thanh tiến trình

28_pytest_passed.png

ẢNH CẦN BỔ SUNG: 28_pytest_passed.png
URL: Terminal
Thao tác: Chạy pytest -q
Phải xuất hiện: Dòng tổng kết toàn bộ test đạt

Caption: Dòng tổng kết toàn bộ test đạt